



BASE DE CONOCIMIENTO GENERAL Y ASIGNACIÓN DE ROLES

DISRUPCIÓN DEL FACTOR HUMANO, MATRIZ TECNOLÓGICA Y PLAYBOOK DE DEFENSA

Institución: Duoc UC Sede San Joaquín • Portafolio de Título APT122 • Arquitectura \$0 CLP

1. LA INNOVACIÓN DISRUPTIVA: REMOCIÓN DEL ESLABÓN MÁS DÉBIL (EL FACTOR HUMANO)

En un Centro de Operaciones de Seguridad (SOC) convencional, ante una intrusión crítica masiva, el operador de guardia experimenta un colapso cognitivo y visión de túnel bajo presión extrema. Se enfrenta a un dilema paralizante: ¿Investiga y bloquea la IP en el firewall o llama por teléfono al CISO para alertar? Al intentar hacer ambas cosas a la vez, se cometen errores de digitación, se olvidan datos forenses y el incidente escala.

KRONOS SENTINEL resuelve este cuello de botella desacoplando ambas tareas de forma autónoma:

- **Vía 1 (Contención Técnica en Microsegundos):** El motor en kernel de FreeBSD (pfctl / snort2c) y Suricata Netmap ejecutan el bloqueo atómico sin intervención humana.
- **Vía 2 (Comunicación Táctica Inmediata):** El auto-dialer Asterisk PBX y Google Gemini Live Flash 3.1 llaman por teléfono al CISO y entregan un debriefing hablado en tiempo real, sin titubeos ni bloqueos emocionales.

2. MATRIZ MAESTRA DE LAS 10 TECNOLOGÍAS DEL SISTEMA (\$0 CLP)

Tecnología	Licencia	Justificación y Rol Táctico en KRONOS SENTINEL
pfSense CE 2.9.0	Open Source	Firewall perimetral base, soporte VLAN 802.1Q y gestión de paquetes.
FreeBSD pfctl / snort2c	BSD (\$0)	Filtrado atómico en kernel de FreeBSD con tabla dinámica en RAM.
Suricata 7.x (Netmap)	GPLv2 (\$0)	Inspección profunda multihilo e interceptación Inline IPS en ring-buffers.
ET Open Rules	Free Tier	Más de 30,000 firmas comunitarias para SQLi, exploits web y shellcodes.
pfBlockerNG-devel	Open Source	Reglas flotantes perimetrales prioritarias para GeoIP y listas C2.
MaxMind GeoLite2	Free Tier	Base de geolocalización IP para reporte verbal de país al CISO.
HAProxy 2.8+ SSL	GPLv2 (\$0)	Terminación SSL 443, rate limiting y stick-tables anti-fuzzing L7.
Asterisk 20 LTS	GPLv2 (\$0)	Telefonía SIP PJSIP y auto-dialer instantáneo vía comandos AMI.
Gemini Live Flash 3.1	Free Tier	Streaming de audio bidireccional por WebSocket para diálogo interactivo.
Tailscale Subnet Router	Free Tier	Malla WireGuard Zero Trust para conectar softphone móvil sin abrir puertos.

3. GUÍA DE ROLES TÉCNICOS Y RESPONSABILIDADES

ROL 1: BRUNO URREA ORTIZ — LÍDER DE CIBERSEGURIDAD, MOTOR PFCTL & GEMINI LIVE

- **Responsabilidades:** Arquitectura global, motor de correlación en Python 3.12 (`log_correlator.py`), algoritmo de supresión de falsos positivos con análisis sintáctico AST (`false_positive_filter.py`), verificación en kernel (`pfctl_wrapper.py`) e integración WebSocket con Gemini Live Flash 3.1.
- **Checklist Operativo:** 1) Levantar `log_correlator.py` → 2) Exportar `GEMINI_API_KEY` → 3) Iniciar `dispatcher.py` → 4) Ejecutar pruebas de inyección SQL con `curl` simulado.
- **Defensa:** Explicar cómo el análisis AST descarta el 50% de alertas ruidosas y cómo la tabla `ip_block` almacena IPs en RAM sin saturar el disco.

ROL 2: FREDDY VÁSQUEZ CORTÉS — ROUTING, SWITCHING & TELEFONÍA VOIP ASTERISK

- **Responsabilidades:** Troncal 802.1Q en pfSense, segmentación de subredes VLAN (Corp 10, DMZ 20, VoIP 30, Mgmt 99), centralita Asterisk 20 LTS en Docker (`pjsip.conf`, `extensions.conf`, `rtp.conf`), script de disparo telefónico AMI (`call_trigger.py`) y enrutamiento Tailscale.
- **Checklist Operativo:** 1) `docker compose up -d` en `src/asterisk_pbx/` → 2) Validar registros `pjsip show endpoints` → 3) Probar disparo directo a `PJSIP/1001` → 4) Validar subred `192.168.30.0/24` en consola Tailscale.
- **Defensa:** Justificar por qué una llamada SIP irrumpe con mayor efectividad que un correo y cómo el aislamiento en VLAN 30 protege la PBX de ataques originados en la DMZ.

ROL 3: CRISTÓBAL QUEZADA — SERVICIOS WEB, PROXY INVERSO HAPROXY & DMZ DVWA

- **Responsabilidades:** Configuración de HAProxy 2.8+ en pfSense, Frontend HTTPS VIP (443) con SSL Offloading, Stick-Tables dinámicas en memoria RAM para mitigación de DoS/Fuzzing L7 (`store http_req_rate(10s),http_err_rate(10s)`) y administración del contenedor vulnerable controlado DVWA en VLAN 20 (`192.168.20.50`).
- **Checklist Operativo:** 1) Levantar contenedor `docker-compose.dvwa.yml` → 2) Validar frontend y backend en HAProxy → 3) Comprobar respuestas `429 Too Many Requests` ante ráfagas de pruebas.
- **Defensa:** Explicar cómo HAProxy oculta la infraestructura real de backend y normaliza las cabeceras HTTP antes de que el tráfico alcance a Suricata.

ROL 4: KEVIN RETAMALES — HARDENING PERIMETRAL, PFBLOCKERNG & CONTROL DE CALIDAD (QA)

- **Responsabilidades:** Hardening del kernel pfSense CE 2.9.0, política de aislamiento Zero Trust, integración comunitaria MaxMind GeoLite2 Free, configuración de feeds de reputación FireHOL Level 1 y Spamhaus DROP en pfBlockerNG-devel, y ejecución de matrices de control de calidad QA.
- **Checklist Operativo:** 1) Comprobar tablas perimetrales `pfctl -s Tables | grep pfB_` → 2) Validar log de bloqueos `/var/log/pfblockerng/ip_block.log` → 3) Ejecutar matriz de pruebas QA de extremo a extremo.
- **Defensa:** Demostrar cómo las reglas flotantes bloquean botnets en la primera capa y justificar el cumplimiento de costo \$0 con la cuenta comunitaria de MaxMind.

4. PROTOCOLO DE DEMOSTRACIÓN EN VIVO (PLAYBOOK DE DEFENSA)

1. **Inyección SQL en DVWA:** El atacante lanza `admin' OR '1'='1 --` contra la web expuesta.
2. **Bloqueo en Kernel:** Se proyecta la consola SSH de pfSense mostrando el drop en Netmap y la entrada en `ip_block`.
3. **Timbrado Telefónico:** El celular del CISO timbra en vivo vía Asterisk PJSIP.
4. **Debriefing Gemini Live:** Se activa el altavoz y la IA informa los datos forenses respondiendo preguntas en tiempo real.